

Granskning av informationssäkerhet i skolsystemet IST administration

Sammanfattande bedömning

Stadsrevisionen har granskat utbildningsnämndens och grundskolenämndens informationssäkerhetsarbete i det skoladministrativa systemstödet IST Administration. Vår sammanfattande bedömning är att nämnderna inte bedrivit informationssäkerhetsarbetet på ett sådant sätt att konfidentialitet, riktighet och tillgänglighet kan säkerställas i den information som hanteras i skolsystemet IST Administration. Vi noterar i sammanhanget att de granskade nämnderna tog över systemansvaret relativt nyligen – den förste augusti 2022 – men att de behöver vidta åtgärder för att hantera de förbättringsområden som framkommer i granskningen.

Rapportsammandraget baseras på rapporten Granskning av informationssäkerhet i skolsystemet IST Administration som finns på www.goteborg.se/stadsrevisionen.

Granskningens utgångspunkter

IST Administration var tidigare ett systemstöd som tillhandahölls stadens skolförvaltningar som en kommungemensam intern tjänst av nämnden för Intraservice. En konsekvens av förändringarna i stadens styrsystem för digital utveckling och förvaltning blev att IST Administration den 1 augusti år 2022 övergick till bland annat utbildningsnämnden och grundskolenämnden som ett verksamhetsspecifikt system. Detta innebär att mottagande nämnder i egenskap av att vara informationsägare helt övertog ansvaret för arbetet med informationssäkerheten i systemet. Syftet med granskningen har varit att bedöma om nämnderna bedriver ett informationssäkerhetsarbete som säkerställer konfidentialitet, riktighet och tillgänglighet i de informationstillgångar som hanteras i IST Administration. Syftet har brutits ned i sju revisionsfrågor:

1. Har nämnderna säkerställt att det för IST Administration finns en ändamålsenlig organisation med en tydlig roll-, ansvars- och befogenhetsfördelning i informationssäkerhetsarbetet?
2. Har nämnderna säkerställt att det finns rutiner som medför att lämnade behörigheter att ta del av, ändra eller lägga till information i IST Administration är aktuella och korrekta?
3. Har nämnderna säkerställt att skyddade personuppgifter hanteras på ett sådant sätt att de inte röjs för obehöriga?
4. Har nämnderna säkerställt att säkerhetsmonitorering, inkluderande loggning av säkerhetsrelevanta händelser sker på ett ändamålsenligt sätt i IST Administration?

5. Har nämnderna säkerställt att det för IST Administration finns tillfredsställande rutiner för säkerhetskopiering av program och data samt för återläsning av data?
6. Har nämnderna säkerställt att det för IST Administration finns en aktuell, dokumenterad och beslutad kontinuitetsplan?
7. Har nämnderna säkerställt att informationssäkerhetsnivån i IST Administration löpande är acceptabel, att det följs upp årligen och att nämnden erhåller en rapport av resultaten av denna uppföljning?

lakttagelser och bedömningar

Organisation och ansvar

Vår bedömning är att utbildningsnämnden och grundskolenämnden vid tiden för granskningens genomförande inte säkerställt att det för IST Administration finns en ändamålsenlig organisation med en tydlig roll-, ansvars- och befogenhetsfördelning i informations-säkerhetsarbetet.

Av granskningen framgick att organisation och ansvarsfördelning uppfattas som otydlig av de granskade förvaltningarna och att den förvaltningsorganisation som förutsätts i avtalet med leverantören av systemet ännu inte etablerats.

Vi lämnar följande rekommendation:

Stadsrevisionen rekommenderar utbildningsnämnden och grundskolenämnden att etablera en organisation med tydlig roll-, ansvars- och befogenhetsfördelning i informationssäkerhetsarbetet kring IST Administration. I detta ingår även att etablera och bemanna den förvaltningsorganisation som förutsätts i avtalet med leverantören av IST Administration.

Behörighetshantering

Vår bedömning är att utbildningsnämnden och grundskolenämnden inte har etablerat rutiner som säkerställer att lämnade behörigheter för att ta del av, ändra eller lägga till information i IST Administration är aktuella och korrekta.

Av Göteborgs Stads riktlinje för informationssäkerhet framgår att regelverk och rutin för registrering och avregistrering av behörigheter och åtkomst samt tilldelning av lösenord för IT-baserade informationssystem ska dokumenteras och finnas formellt beslutad. Granskningen visar att varken utbildningsnämnden eller grundskolenämnden har något beslutat regelverk för hanteringen av behörigheter i IST Administration.

Vi lämnar följande rekommendation:

Stadsrevisionen rekommenderar utbildningsnämnden och grundskolenämnden att besluta om ett regelverk för hanteringen av behörigheter i IST Administration.

Hantering av skyddade personuppgifter

Både förvaltningen hos utbildningsnämnden och grundskolenämnden har gjort bedömningen att IST Administration inte är tillräckligt säkert för att hantera elever med skyddade personuppgifter. Hos utbildningsnämnden registreras elever med skyddade personuppgifter med en pseudonym i systemet. Grundskolenämnden tillämpar en manuell rutin för hanteringen av elever med skyddade personuppgifter helt utanför systemet. Rutiner och riktlinjer för respektive nämnds hantering har beslutats.

Stadsrevisionen noterar att nämnderna vidtagit åtgärder för att hantera systemets brister när det gäller hanteringen av skyddade personuppgifter. Vi ser dock att hanteringen öppnar upp för risker kopplade till informationens riktighet och spårbarhet när det gäller elever med skyddade personuppgifter. Det är angeläget att nämnderna i det fortsatta arbetet bidrar till att reducera dessa risker.

Säkerhetsmonitorering och loggning

Ansvar för att hantera säkerhetsmonitorering och loggning av säkerhetsrelevanta händelser ligger enligt tecknat avtal hos leverantören av IST Administration. Utbildningsnämnden och grundskolenämnden har inom ramen för sina respektive informationssäkerhetsansvar att genomföra efterlevnadskontroller i syfte att säkerställa leverantörens arbete med säkerhetsmonitorering och övervakning fungerar på det sätt som avtalats.

Den senaste efterlevnadskontrollen av leverantörens säkerhetsmonitorering och loggning av säkerhetsrelevanta händelser år 2019 visade på brister i systemet. Efter detta har ingen efterlevnadskontroll genomförts av systemets förmåga att på ett ändamålsenligt sätt övervaka och logga säkerhetsrelevanta händelser.

Vår bedömning är att nämnderna utifrån sitt informationssäkerhetsansvar behöver säkerställa leverantörens förmåga att i systemet logga och övervaka säkerhetsrelevanta händelser.

Vi lämnar följande rekommendation:

Stadsrevisionen rekommenderar utbildningsnämnden och grundskolenämnden att regelbundet genomföra efterlevnadskontroller av leverantörens arbete med säkerhetsmonitorering.

Säkerhetskopiering och återläsning av data

Den senaste kontrollen av säkerhetskopiering och återläsning av data skedde i samband med den efterlevnadskontroll som gjordes när systemet levererades till Intraservice 2019. Vår bedömning är att utbildningsnämnden och grundskolenämnden inte säkerställt att det finns tillfredsställande rutiner för säkerhetskopiering och återläsning av data. Vi gör bedömningen att det finns behov av en mer regelbunden och stärkt kontroll av leverantören för att säkerställa att den information som ska finnas tillgänglig är säkerhetskopierad och går att återläsa vid behov.

Vi lämnar följande rekommendation:

Stadsrevisionen rekommenderar utbildningsnämnden och grundskolenämnden att säkerställa att de av leverantören gjorda säkerhetskopiorna är möjliga att återläsa.

Kontinuitetsplan

Vår bedömning är att utbildningsnämnden och grundskolenämnden inte säkerställt att det finns en aktuell, dokumenterad och beslutad kontinuitetsplan för IST Administration vid tidpunkten för granskningens genomförande. En formellt beslutad kontinuitetsplan ska ange hur lång tid informationssystemet kan vara otillgängligt innan verksamheten påverkas i oacceptabel omfattning. Kontinuitetsplanen ska därutöver innehålla återstarts- och reservrutiner så att återstart kan ske inom fastställd tid samt rutiner för säkerhetskopiering och återläsning. Kontinuitetsplanen ska hållas aktuell och helt eller delvis testas årligen.

Båda nämnderna uppger att de påbörjat arbetet med att upprätta kontinuitetsplaner för IST Administration. Stadsrevisionen vill understryka vikten av att utbildningsnämnden och grundskolenämnden säkerställer att en kontinuitetsplan för IST Administration beslutas.

Uppföljning

Vår bedömning är att varken utbildningsnämnden eller grundskolenämnden genomfört någon uppföljning eller kontroll av informationssäkerhetsnivån efter övertagandet av ansvaret för IST Administration i augusti månad år 2022. Uppföljning och kontroll av att informationssäkerhetsnivån är acceptabel ska enligt stadens riktlinje för informationssäkerhet minst ske årligen och resultatet av uppföljningen ska rapporteras till respektive nämnd.

Uppföljning av informationssäkerhetsnivån genomfördes senast vid efterlevnadskontrollen år 2019. Stadsrevisionen vill understryka vikten av att nämnderna säkerställer att kontroll av informationssäkerhetsnivån i IST Administration sker årligen.

Stadsrevisionen

Postadress: Box 2141, 403 13 Göteborg

Besöksadress: Stora Badhusgatan 6, Göteborg

Kontaktcenter: 031-365 00 00, kansli: 031-368 07 00

stadsrevisionen@stadsrevisionen.goteborg.se

www.goteborg.se/stadsrevisionen